项目技术报告

cv-agent

当前系统设计、逻辑与流程

源码检索、任务规划、多专家审查、证据准入与有界执行见证

记录日期	2026 年 9 月 30 日
实现基线	Git `4dba622db459d4487bc8493b9af3a6a5f40a3387`
最近代码迁移	`af7024d`：见证运行时迁入 `runtime/witness/`
工作树说明	在上述提交之上，最终汇总 JSON 已同步收尾状态；本报告不修改检测实现。
描述范围	当前源码、测试契约、已归档验收记录与正式 G-A 判定。
核心定位	面向明确候选的、受证据与预算约束的分析研究系统；有界见证用于少量已选定候选的条件确认。

本报告中的结果均附带其数据角色、证明范围和验证方式。工程验收、模型实验与研究泛化结论分别表述。

摘要

cv-agent 将源码安全审查拆成可审计的多个环节：源文件解析和候选发现、固定预算的 Code-RAG、验证任务规划、三类专家的模型与工具循环、候选绑定的证据准入、最终单票或 quorum 仲裁，以及独立的实验计分与用量账本。模型负责提出取证动作和结构化结论，验证器与运行时负责约束身份、范围、前提、投递状态和预算。系统将预测标签与验证状态分开，静态可疑模式和可能数据流不会自动成为漏洞确认，无法支持的语义保留为未解析。

当前实现包含 E1–E5 候选审查系统、Python 主导的静态分析、多语言源码适配器、类型化验证工具、可选 Jev 规划分流、离线回归与真实模型调用准入，以及源码绑定的正向执行见证。2026 年 9 月 30 日的收尾记录表明，K2 运行时迁移已验收；给定开发脚本场景时，两版真实快照分别保持确认与字面量未决结果。M0 与追加 E-iter 的真实模型运行均未建立自主确认正例，外部迁移样本没有完成准入，正式门槛 G-A 为 NO，K5–K8 未启动。

本文从数据对象、控制流、算法、接口和生命周期解释当前系统，并将实现事实、已枚举的测试保障、实验观察和未来扩展分别标明。报告不将测试通过、开发配对或投票一致性解释为完整应用安全证明，也不将历史开发成绩解释为 held-out 泛化性能。

关键词：代码检索；候选身份；ReAct；任务依赖；证据准入；有界执行；三值判决；实验记账。

目录

1 问题定义、描述范围与设计原则 **1**
1.1 系统要解决的问题 1
1.2 当前系统的完成边界 1
1.3 五项贯穿系统的原则 1
1.4 证据来源与时态 2

2 分层架构与责任边界 **2**
2.1 总体数据流 2
2.2 源码包结构 2
2.3 K2 后的见证运行时分层 4

3 数据模型与候选身份 **4**
3.1 不可变外壳与结构校验 4
3.2 源码摘要的构造 5
3.3 位置、性质与范围 5
3.4 预测状态与验证状态 5

4 源码发现与多语言适配 **5**
4.1 仓库级候选发现 5
4.2 多语言解析层级 6

5 Code-RAG、图绑定与上下文预算 **7**
5.1 文档索引和图构造 7
5.2 默认文本评分与 BM25 诊断 7
5.3 同一局部基底与图、文本增强 7
5.4 两层文本预算与 API 用量 8
5.5 模型投影与路径准入 8

6 系统变体、专家职责与计划 **9**
6.1 E1–E5 的受控差异 9
6.2 三种专家职责 9
6.3 类型化计划与确定性义务 9
6.4 LangGraph 的实际执行方式 10

7 ReAct 循环、工具执行与预算终止 **10**
7.1 从模型动作到最终 JSON 10

7.2 工具边界的处理顺序 . . . 11
7.3 完整观察与模型可见载荷 . . . 11
7.4 多个子任务的共享预算 . . . 11
7.5 正常收尾、弃权与错误 . . . 11

8 证据准入与语义契约 12
8.1 准入不是另一次模型投票 . . . 12
8.2 supporting、counter 与 unresolved 的角色 . . . 12
8.3 静态事实与候选证明的门槛 . . . 13
8.4 C1–C6 的规范职责 . . . 13

9 静态分析器与类型化验证工具 14
9.1 命令分析的有界语义 . . . 14
9.2 数据流与消费上下文 . . . 14
9.3 权限 mode 验证 . . . 14
9.4 动态求值的 AST 探针 . . . 15
9.5 授权事实、差分与 registered fixtures . . . 15
9.6 执行隔离的适用假设 . . . 15

10 源码绑定的正向执行见证 16
10.1 为什么需要单独的见证接口 . . . 16
10.2 清单、执行上下文与准备状态 . . . 16
10.3 分类场景与双 subject . . . 16
10.4 真实目标、候选帧与源码库存 . . . 17
10.5 运行时义务的四类检查 . . . 17
10.6 入口适配与环境准备 . . . 18
10.7 资源配置与可复现环境 . . . 19
10.8 compact 投递与私有完整产物 . . . 19

11 Jev 分流与政策组合 19
11.1 定位与传输契约 . . . 19
11.2 off、shadow、active 与版本差异 . . . 20

12 最终投票、早停与共享观察 20
12.1 单票与 quorum 规则 . . . 20
12.2 E5 的提前终止保证 . . . 20
12.3 共享票与原始观察计数 . . . 21

13 模型传输、日志与实验预算 **21**
13.1 所有真实模型调用的唯一准入链 21
13.2 测试隔离与凭据处理 21
13.3 先记录 usage，再验证响应内容 22
13.4 耐久事件与全局停止 22

14 评价层、配置组合与实验生命周期 **22**
14.1 配置按职责组合 22
14.2 候选执行与结果状态 23
14.3 实验生命周期 23
14.4 检测输入与评价标签分离 23
14.5 运行完整性与研究 claim readiness 24

15 三值评价指标与成本归因 **24**
15.1 保留完整分母 24
15.2 区间与配对比较 25
15.3 成本的三个维度 25

16 当前验收记录、实验观察与正式决策 **26**
16.1 K1–K4 的工程结果 26
16.2 M0 与 E-iter 的调用账本 26
16.3 失败分类与归因规则 27
16.4 近迁移、外部样本与 G-A 27

17 测试体系、回归要求与有效覆盖 **28**
17.1 验证方法 28
17.2 T01–T16 的主链验收类别 28
17.3 关键测试入口 29

18 能力边界与后续设计 **29**
18.1 当前可以依赖的能力 29
18.2 当前限制及原因 30
18.3 已列出的扩展选项 30

19 报告的复现与来源管理 **31**
19.1 文档构建 31
19.2 引用规则与事实更新 31

A 核心模块阅读索引 **32**

B 工具目录与输出解释 **33**

C 单候选审查的完整记录链 **34**

D 术语对照 **35**

1 问题定义、描述范围与设计原则

1.1 系统要解决的问题

项目的基本输入是一个源码快照及待检查候选，基本输出是带证据、执行轨迹、范围和用量的结构化判决。候选可能来自确定性扫描器，也可能来自显式配置的开发任务。系统目标是在有限上下文和模型调用预算内，回答候选所声明的具体性质是否得到支持。

本文用 R 表示源码快照，c 表示候选，p 表示待判定性质，Γ 表示输入、配置和环境前提，Ω 表示覆盖范围。一次有效判断的对象可写为

$$J = (R, c, p, \Gamma, \Omega). \tag{1}$$

例如，某个调用是否可能消费未经保护的输入、某个权限 mode 是否具有指定比特，以及一个完整应用是否存在可远程利用的漏洞，是不同的判定对象。验证器只能支持与自身实际证明范围一致的对象。

系统同时存在两种输入流程。**候选审查流程**从已经定位的 Candidate 开始；**源码发现流程**遍历仓库、建立索引和候选清单，再在独立的 runner 中安排审查或由 evaluator 对发现位置计分。当前若干配对矩阵直接使用预选候选，并没有经过源码自动发现。这些结果不能外推为 repository-only 的端到端发现能力。

1.2 当前系统的完成边界

当前可确认的工程事实是模型与工具工作流已经实现，关键语义与准入链具有离线正反控制，见证运行时已完成结构迁移。当前可确认的见证事实是，在开发者给定的分类场景下，少量候选可产生源码绑定的条件确认。

当前真实模型实验没有建立自主场景提出成功，也没有完成外部项目迁移成功。正式 G-A 判定为 NO。因此，本文把现有执行见证定位为**对少量已选定候选做有界确认的工具**。这是本轮实测后的定位，不能以最初目标规格替代。[2, 18, 17]

1.3 五项贯穿系统的原则

1. **先绑定对象，再解释状态**。仓库、源码摘要、位置、性质、范围与前提都是候选身份的一部分。
2. **观察与证明分层**。读到源码、命中模式、发现可能流、得到有界性质证明和获得条件执行见证，各自支持不同强度的结论。
3. **未知保持未知**。无法解释的调用、对象协议、副作用、控制流或环境失败，不能通过字符串命名或多数票升级为安全或漏洞事实。
4. **控制预算但不降低证据门槛**。预算决定还能执行哪些动作，不能决定同一证据突然变得充分。
5. **把运行和科学结论分开**。测试准入、实验完成、证据充分、统计可解释及研究 claim readiness 是独立关口。

1.4 证据来源与时态

本报告以当前 `src/cv_agent/` 为实现依据，以 `docs/TEST_CONTRACT.md` 为语义规范，以 2026-09-30 的 K2、M0、E-iter、正式 G-A 和定位报告为完成状态依据。旧设计文档与历史产物用于解释背景，只有明确与当前源码一致的部分才进入当前实现描述。

当前源码树含 217 个 Python 模块，顶层 `tests/test_*.py` 文件共 156 个；这两个数量是文档整理时的文件清点，不是功能覆盖率。已有最终完整测试日志记录 2562 项通过。本报告编写只做源码与记录阅读，没有重新调用模型或运行真实目标见证。

2 分层架构与责任边界

2.1 总体数据流

图 1 描述当前核心对象如何在各层流动。检索、工具观察和专家票通过不同的数据对象表达；实验标签由评价侧保管，不沿检测数据流进入模型。

2.2 源码包结构

表 1: 当前包的职责与文件数量。数量包括包初始化模块。

包	模块数	职责
`domain`	6	候选、源码文档、验证 subject、观察、聊天消息、任务计划与结果 schema。
`code_adapters`	11	多语言解析、符号与调用元数据、源码边界读取、fallback 文档。
`retrieval`	6	文档索引、词法排序、图遍历、上下文裁剪、可选 BM25 诊断。
`tools`	26	工具注册、输入校验、作用域、静态分析、权限与授权验证、受控夹具和见证封装。
`agents`	12	源码发现、扫描器、计划、ReAct、证据准入、任务调度、投票和原始观察计数。
`runtime`	26	模型传输、门禁、预算、日志、快照、隔离、见证入口与 `runtime/witness/` 内核。
`harness`	7	类型化实验契约、默认系统、能力声明、结果和约束核对。
`evaluation`	107	数据与协议组装、单候选执行、实验生命周期、发现计分、runner、准备与诊断。
`baselines`	14	保留的确定性 V 系列、专家规则、OWASP 和 synthetic 对照。
包根目录	2	初始化和 `cli.py` 命令入口。

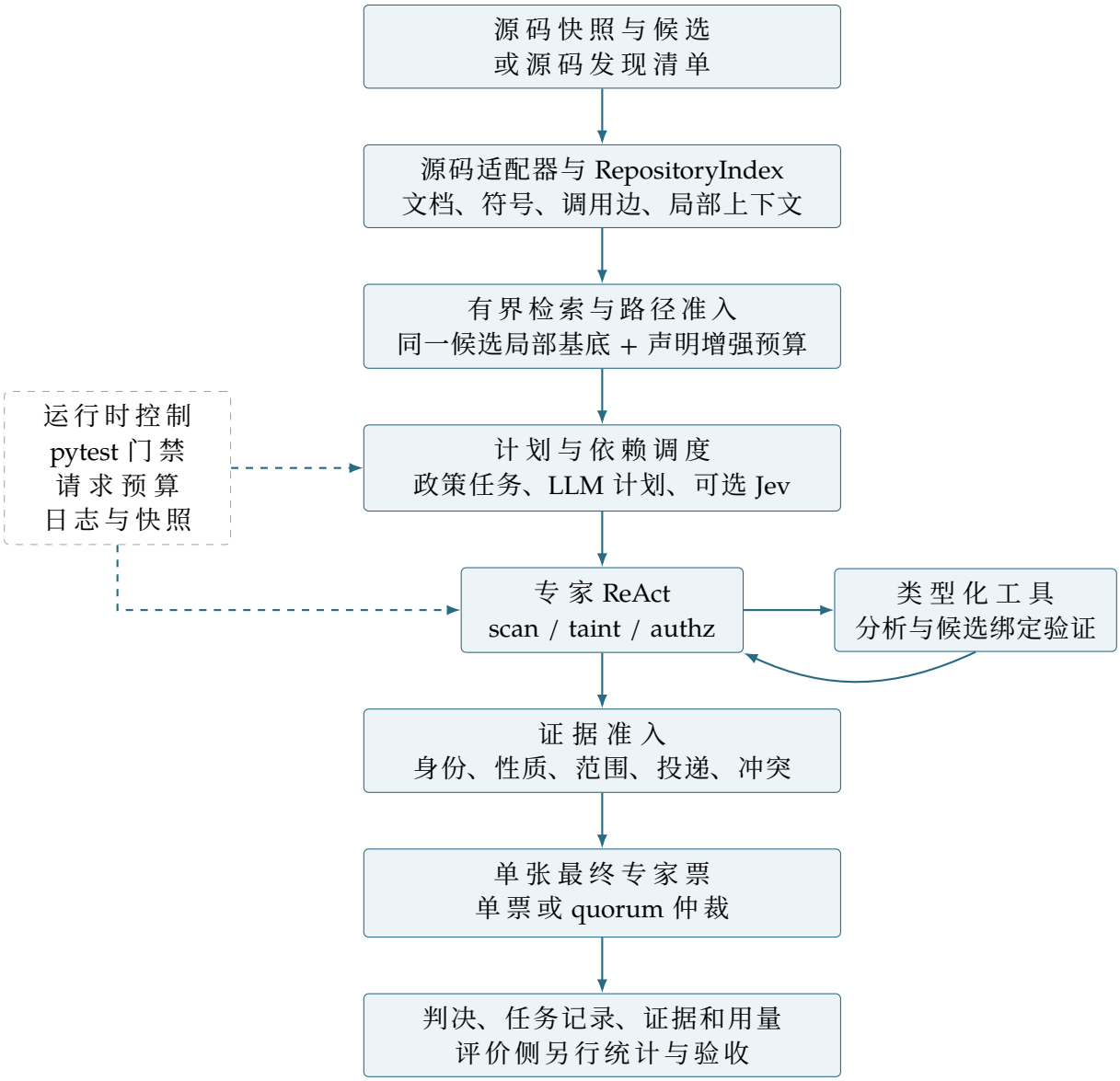


图 1: 当前系统的主数据流。每条执行路径都受运行时约束，评价侧标签不作为检测输入。

数据模型描述事实；分析器解释有限语义；验证封装记录证明范围；证据准入决定某一结论是否可接受；仲裁仅聚合已经通过准入的票。准入层不应重新解析源码来补分析器缺失的事实，投票层也不应把弱观察升级成证明。

2.3 K2 后的见证运行时分层

当前见证内核位于 `runtime/witness/kernel.py`，契约、隔离读取策略、追踪、资源计数、场景运行及值、分支、preexec 义务分别位于同一运行时包下。生产工具 `bounded_witness.py` 和 `witness_manifest.py` 依赖运行时；环境准备、实验 runner 与诊断仍位于 evaluation。

核心 `agents`、`tools`、`runtime` 包不再反向导入 evaluation。边界测试检查显式、嵌套、类型检查和所列字面动态导入，并确认旧模块已移除。该检查不宣称可以穷尽任意动态构造的导入字符串。迁移后旧上下文因引用已不存在的运行时源码路径被拒绝，必须重建上下文；这体现了上下文与运行时身份的绑定。[10]

3 数据模型与候选身份

3.1 不可变外壳与结构校验

领域模型继承 `FrozenModel`，其 Pydantic 配置为 `extra="forbid"` 和 `frozen=True`。外部数据需要通过 schema 校验，未知字段不被静默接受。这里的 frozen 是模型外壳约束，不能被解释为所有嵌套容器的深层不可变或应用级并发安全。

表 2: 核心数据对象及其语义。

对象	关键内容与作用
`Candidate`	候选与案例标识、仓库、路径和行号、检索 query、显式 `property_id` 与 `analysis_scope`、输入参数及场景前提。
`CodeDocument`	源码切片、语言与适配层级、定义、调用、导入、路由、守卫、别名与重绑定；适配器提供时包含完整源文件摘要。
`Evidence`	检索证据标识、路径、文本、检索方式、排序分数与图距离；本身不表示验证成功。
`ValidationSubject`	候选身份、源码索引摘要、位置、性质、范围和前提；所有匹配证明共用这一绑定载体。
`ToolObservation`	工具名、执行状态、内容、引用、元数据、验证状态、subject 与 fixture proof scope。
`ValidationSubtask`	任务标识、目标、专家、允许验证器、依赖、成功条件及可选 fixture 案例绑定。
`AgentExpertVote`	标签、置信度、验证状态、不同角色的引用、理由、轨迹、模型与工具调用次数、观察预算与 usage。

对象	关键内容与作用
`AgenticVerdict`	最终判决、single/fast/slow 路径、最终专家票、所有任务执行、阻塞任务、检索准入、共享观察计数与总用量。

实现定位：`src/cv_agent/domain/types.py;domain/evidence.py;domain/review.py;domain/chat.py`

3.2 源码摘要的构造

`candidate_subject(index,candidate)` 是核心和 fixture 共用的身份入口。索引摘要按文档路径排序，对完整文档模型作规范 JSON 序列化，再取 SHA-256。它覆盖被索引的文本及其语义元数据；适配器提供的非空 `source_sha256` 也参与摘要。

必须区分**索引摘要**和**完整检出树身份**。Java 方法文档已有完整文件摘要，用于识别方法外 imports、字段等变化；没有提供全文件摘要的其他文档，不因此自动获得相同完整性。执行见证另行维护并核对真实源码模块清单，不能只靠一个方法切片的文本摘要代替运行绑定。

实现定位：`src/cv_agent/tools/identity.py;code_adapters/java.py;tools/validation/witness_manifest.py`

3.3 位置、性质与范围

解析文档可使用 `file::symbol@start-end` 这样的切片路径。生产准入需要将原始行号转换成局部行号并检查候选是否落在所检查范围内；函数头候选与某行候选的覆盖语义不同。装饰器、切片偏移、helper 调用来源和同文件多个 sink 都不能靠名字相似来替代位置绑定。

`property_id` 明确区分命令执行、动态求值、权限 mode 等性质。权限位模式证明只适配 `chmod-mode-others-write`；Java 的固定 token 到达性质不等于完整命令执行性质；一个局部 helper 的返回值事实也不能成为调用方整体安全证明。缺少性质时可展示局部事实，但不能自行从标签、案例名或路径别名补齐证明义务。

3.4 预测状态与验证状态

预测标签与验证状态分别属于

$$y \in \{\text{VULNERABLE}, \text{SAFE}, \text{ABSTAIN}\}, \tag{2}$$

$$v \in \{\text{CONFIRMED}, \text{REFUTED}, \text{UNRESOLVED}\}. \tag{3}$$

工具执行状态另外使用 `ok/error/blocked`。这三个维度分别表示结论、证明进度和操作结果。

情况	可接受的表达	所需条件
充分候选正向证明	VULNERABLE / CONFIRMED	身份、性质、范围、前提、引用与完整投递一致。
充分候选否定证明	SAFE / REFUTED	证明覆盖声明范围；没有相关未解析副作用或证明冲突。
有界静态性质支持预测	V 或 S / UNRESOLVED	仍须满足该性质的具体准入要求，不能仅凭模式或可能流。
证据不足或运行缺口	ABSTAIN / UNRESOLVED	保存未解析原因；不把失败观察解释为 SAFE。
字面量见证观察	ABSTAIN / UNRESOLVED	当前正向见证不提供 REFUTED 或 SAFE。

表 3: 状态组合的解释。CONFIRMED 的含义由验证器实际证明范围决定。

4 源码发现与多语言适配

4.1 仓库级候选发现

`discover_python_repository` 以确定性的路径顺序遍历 Python 文件，排除版本库、虚拟环境、依赖和构建目录；通过源码读取边界读取字节，记录文件 SHA-256，检测编码并解析函数切片。同时增加完整模块文档，用于保留导入时操作和类体。

`StaticScanner` 根据 AST 调用、已解析别名、路由装饰器和有限规则，生成命令执行、动态求值、数据库操作、模板操作、权限 mode、授权边界、动态属性和进程控制等候选。重叠模块与函数切片按最小适用 span 去重。稳定候选标识由仓库、源文件、行号和规则生成，标识不是期望标签。

解析失败作为清单的一部分保留，不从分母中静默消失。扫描报告明确 `discovery_is_validation=false`。一些 pilot 明确采用有限候选前缀；这属于被记录的实验选择，不能被说成全仓所有候选已审查。源码发现、位置匹配、候选标签判断和运行时见证必须分别统计。

实现定位：`src/cv_agent/agents/discovery.py;agents/scanner.py;evaluation/discovery.py`

4.2 多语言解析层级

Python 适配器基于 AST 保存函数范围、调用、导入别名和模块绑定；Java、JavaScript/TypeScript、Go 使用对应解析支持构造文档与调用元数据。对不具有相同语义覆盖的格式，系统保留显式 fallback 文档。

源文件读取使用相对目录描述符并拒绝符号链接，包括路径中的链接父目录。这样可以阻止普通索引步骤通过 symlink 越出源码树。这个读取约束不替代执行环境中的资源与文件系统隔离。

实现定位：`src/cv_agent/code_adapters/source_files.py;code_adapters/repository.py`

层级	实际提供的信息及限制
Python AST	函数与方法切片、别名与调用元数据；部分有界值、数据流、命令和权限语义。
Java 解析	方法文档、调用、完整原文件摘要与有界项目夹具；不代表一般 Java 应用验证。
JS/TS 与 Go 解析	定义、形式参数、调用和路由等结构；当前非 Python flow 仍包含有限逐行近似。
Fallback	文件级或文本级的 imports、配置、轨迹相关上下文；不得报告为完整 AST 调用图或深层语义证明。

表 4: 适配器层级说明。解析能力与漏洞证明能力是两个不同维度。

5 Code-RAG、图绑定与上下文预算

5.1 文档索引和图构造

`RepositoryIndex` 拒绝重复文档路径，保存源码词频、路径词频、定义表、前向及反向调用边。图边必须根据已知限定名、导入别名和源文件关系建立；已知外部调用不得连接到无关的同名本地函数。一个图邻居表示检索候选关系，不自动证明动态调用可达。

检索支持 local、text、graph 和 hybrid。graph 在声明方向上进行有界遍历，再按词法相关性或距离排序；`both` 模式保留前向路径优先信息。直接解析出的相关 callee 可以优先准入，并记录跳过原因、调用来源、符号、图距离和文档摘要。

实现定位：`src/cv_agent/retrieval/index.py;retrieval/context.py;retrieval/dependencies.py`

5.2 默认文本评分与 BM25 诊断

当前默认文本排序是 TF-IDF 风格的词法评分。设查询词次数为 q_t，文档词频为 $f_{t,d}$，文档总数为 N，文档频率为 df_t，基本项为

$$\mathrm{idf}(t) = \log \frac{N+1}{df_t + 1} + 1, \tag{4}$$

$$s_{\text{text}}(q,d) = \sum_{t:f_{t,d}>0} q_t \left(1 + \log f_{t,d}\right) \mathrm{idf}(t). \tag{5}$$

路径形式的查询还加入路径词、完整路径子串和路径片段加权。这些都是可复核的词法启发式。

`MetadataBM25Index` 是独立的增强词法诊断，使用源码、路径和符号，代码常数对应 $k_1 = 1.2$、$b = 0.75$。它没有替换冻结的默认 E2。旧概述把所有文本检索都简称 BM25 时，本文以实际实现为准。

实现定位：`src/cv_agent/retrieval/index.py::_lexical_scores;retrieval/bm25.py`

5.3 同一局部基底与图、文本增强

所有系统先取得同一候选局部文档。增强结果经过确定性的去重、数量上限与上下文裁剪，避免扩大一个系统的隐藏取证范围。对于较长代码，context 模块可围绕候选、源、sink 及赋值依赖保留局部窗口，并显式标明非相邻上下文省略。

hybrid 将候选出发的图检索、文本检索及词法 seed 出发的图检索按分支上限合并，再受共享文本预算限制。因此，hybrid 的 `top_k` 是分支限额，其联合条数语义与普通 text/graph 的全局条数限额不能混为一谈。与不同检索方法比较时应同时报告实际文档数和序列化预算。

5.4 两层文本预算与 API 用量

旧的确定性实验使用词法上下文单位；当前 agent 对模型可见的序列化文本使用 UTF-8 字节上界。对完整序列化载荷 s，计数为

$$B(s) = |\,\mathrm{UTF8}(s)|. \tag{6}$$

它将候选投影、引用、路径、JSON 转义和内容一起计入相应文本预算。裁剪是在完整序列化后判定能否容纳，长标识符不会被当作一个免费单位。

此计数不是模型服务商的精确 tokenizer 计费。系统指令、工具 schema、历史消息、规划和输出还会增加实际请求 tokens。检索预算、观察预算与 provider usage 应分别记录。

通用 E 系列默认项	默认值	语义
候选局部基底	4096	模型可见序列化文本的上界单位。
增强上下文	12288	E2–E5 的声明增强预算；E1 为 0。
增强条数	12	普通文本/图检索的默认 top-k。
图距离上限	4	E3–E5 默认最大跳数。
ReAct 步数	8	一次任务循环的最大模型步数。
工具观察预算	8192	同一专家多个子任务累计共享。
规划子任务上限	8	计划的有限规模约束。

表 5: 默认值来自 Harness；专项 profile 可声明不同策略，报告实验时必须使用其实际配置。

实现定位：`src/cv_agent/harness/defaults.py;retrieval/tokens.py;agents/workflow.py::_bounded_context_prompt`

5.5 模型投影与路径准入

初始模型上下文仅包含显式候选投影及被选中的检索文档。候选投影包含中性身份、仓库、路径、行号和明确的性质、分析范围；私有 query 与任意 caller metadata 不直接复制给模型。

工具作用域的 admitted paths 来自最终实际投递的文档集合。工具可以重读、搜索或遍历其中已准入的路径，但不能将 local 系统扩成全仓检索。证据路径准入只约束 agent 的取证范围；见证内核执行目标时另有真实源码闭包绑定与文件系统读取准入，二者的用途不同。

6 系统变体、专家职责与计划

6.1 E1–E5 的受控差异

系统	检索	Planner	专家	最终规则
E1	local	关闭	scan	单票
E2	text	关闭	scan	单票
E3	graph	关闭	scan	单票
E4	graph	开启	scan、taint、authz	完整 quorum
E5	graph	开启	scan、taint、authz	前两张最终票可尝试早停；否则完整 quorum

表 6: 当前 E 系列默认定义。真实运行使用独立声明的模型与实验配置。

V1–V5 是保留的确定性开发基线，其专家规则、预算和输出不等同 E 系列真实模型循环。V 系列、synthetic 和 scripted 结果用于机制对照，不能充当 live 模型结果。

6.2 三种专家职责

scan 检查源码结构、候选操作和适用的受控验证；taint 分析输入到消费边界的来源、传递、转换与缺边；authz 分析主体、动作、资源或租户、守卫与执行位置。不同任务允许的工具来自各自 Harness，不能让一个不适用专家为了凑票而强行输出实质判断。

各专家可以共享被合法投递的依赖观察，但必须自行形成结构化结论。专家角色不同不意味着其数据或证据统计独立。共享见证的票数和原始见证观察数在结果中另行记账。

默认 E4/E5 使用固定专家集合。可选 `applicable_v1` 将适用性表示为 applicable、not applicable 或 undetermined；明确计划任务仍必须执行，未能排除的专家仍保留。可选政策不会降低 quorum：适用专家不足两名时返回弃权。它是单独实验选项，不能默默替换固定基线。

实现定位：`src/cv_agent/harness/defaults.py;agents/applicability.py`

6.3 类型化计划与确定性义务

`ValidationPlan` 要求至少一个可执行任务，任务标识唯一，目标、专家、验证器和成

功条件非空。依赖必须引用之前出现的已知任务，因此提交的计划本身具有拓扑顺序；未知和前向依赖直接拒绝。

计划不是任意自然语言待办表。policy 层推导必要验证义务：符合完整候选性质范围的 registered fixture 可以替代对应命令检查；适用见证可生成独立 witness 任务，并让后续命令分析依赖其完成；权限 mode 的必要验证义务仍单独保留。任务必须使用专家可调用且已注册的验证器。

`compose_plan` 将政策锁定任务和合法外部提案组合，记录 policy、jev 或 llm 来源。成功条件描述要完成的取证动作，不能被解释为已经满足了漏洞成功标准。

实现定位：`src/cv_agent/agents/planning.py;agents/plan_policy.py;domain/review.py::ValidationPlan`

6.4 LangGraph 的实际执行方式

当前图注册 retrieve、plan、scan、taint、try_fast、authz 和 adjudicate 节点。从 retrieve 到 plan 后，由当前依赖状态选择下一节点。图不是把三名专家无条件同时启动的固定并行流程。

就绪任务需要其所有依赖的 `validator_completed=true`，声明专家顺序只对多个就绪任务作 tie-break。某个专家可以在其他专家执行后恢复；同一专家各子任务的中间判断都保存在 task executions，直到自身全部任务处理完，才使用最后的累积判断生成一张最终票。

Listing 1: 任务调度的概念性逻辑；具体执行与失败记录由 workflow 负责。

```
validated = tasks_with_validator_completed_true(executions)
blocked = propagate_incomplete_dependencies(plan, executions)
ready = [task for task in plan
         if task.not_executed and task.dependencies <= validated]
next_task = choose_by_declared_expert_order(ready)
execute_one_react_subtask(next_task)
record_task_execution_and_completion()
if no_own_task_remains(expert):
    emit_one_cumulative_final_ballot(expert)
```

终止与验证完成分别记录。合法 ABSTAIN 可以结束一个任务，但如果必需验证器没有完成，依赖任务仍被阻塞；一个已经完成而结果为 UNRESOLVED 的验证器可满足调度依赖，却不会因此支持实质漏洞判断。有阻塞必需任务时，工作流最终弃权。

实现定位：`src/cv_agent/agents/workflow.py::_next_task;agents/workflow.py::_blocked_tasks`

7 ReAct 循环、工具执行与预算终止

7.1 从模型动作到最终 JSON

ReAct 输入包含专家 mandate、任务提示、允许工具 schema、最终输出 schema、剩余观察预算和必需验证器。每一步模型可请求类型化工具，或提交最终 JSON。工具

结果经过运行时引用生成、投递裁剪及状态封装后，以 tool message 返回给模型。

最终 JSON 需要通过 schema、专家身份、引用、验证完成与证据准入检查。模型提出的 VULNERABLE 或 SAFE 不是最终获准的票；拒绝原因会作为结构化反馈进入有限的剩余循环。所有已发送模型请求仍计入用量。

实现定位：`src/cv_agent/agents/react.py;domain/chat.py`

7.2 工具边界的处理顺序

注册表首先检查剩余观察预算，再检查专家工具 allowlist、注册与可用性、输入 schema、任务绑定的 fixture ID 和重复调用。执行器只接受已注册工具及数据型参数，不提供任意模型生成 shell 命令的运行接口。

同一子任务中，相同工具名和规范化参数若已成功执行，或生产者已完成，不再次物理执行。后续重复得到 blocked 观察并指向先前引用。重复执行记忆基于**执行事实**，不能因为先前结果在投递时被裁剪而遗忘。另一个子任务有自身 scope，仍可执行其分配的验证器。

工具异常通过类型化边界变成 error 观察；错误工具身份等协议不一致则显式报错。工具调用数是尝试数，包含被拒绝或失败的调用，不能被等同成功验证次数。

实现定位：`src/cv_agent/tools/registry.py::invoke;runtime/journal.py::RecordedTools`

7.3 完整观察与模型可见载荷

生产者的完整结果和模型实际收到的结果是两个记录面。注册表对完整序列化工具响应计数，必要时结构化裁剪。截断、抑制、error 或 blocked 观察不能作为充分证明。发生截断时，传给模型的确认资格及 proof scope 被移除，原始产物则保留供审计。

观察预算耗尽后，诊断信息必须能够到达模型。当前用单独的 Harness 诊断说明预算已尽，且该说明不消耗其报告已经耗尽的预算，避免出现“空 tool message”诱发重复调用。模型随即进入不能新增工具的收尾阶段，证据门槛不降低。

7.4 多个子任务的共享预算

同一专家总观察预算为 B_e，已执行子任务保留累计用量。计划含 n_e 个该专家任务时，第 k 个任务的累计可用上限按任务份额开放，可概括为

$$B_{e,k} = \left\lfloor B_e \frac{k}{n_e} \right\rfloor . \tag{7}$$

这给后续任务保留预算，而前面未用完的份额仍可被后续使用。规划和可选 routing 也有明确计数，不作为免费上下文。该机制不保证模型会采用最有效动作，只保证已声明资源边界可审计。

7.5 正常收尾、弃权与错误

证据充分时可以形成实质票；经过至少一次工具尝试后可以自愿弃权；预算末尾反复坚持证据不足实质标签时，运行时按契约有界弃权，并保留 proposed label、拒绝原因及终止类型。零工具尝试且无法满足 vote schema 的执行返回显式失败或未完成，不伪造工具调用。

未知 citation、subject 漂移、非法协议、模型传输异常和内部错误不能统统归为普通“证据不足”。相反，未解析语义和可说明的预算终止需要保留具体原因，使后续分析可以区分能力、基础设施、协议和资源限制。

8 证据准入与语义契约

8.1 准入不是另一次模型投票

`validate_conclusion` 与相关辅助函数在运行时执行确定性检查。它们核对结论引用了哪些已投递观察、观察是否属于当前候选、其证明范围能否支持预测，以及同范围反证或冲突是否存在。模型置信度不能绕过这些检查。

一个足以支持实质判断的观察至少要同时满足：成功且完整投递、候选及源码身份匹配、性质匹配、覆盖范围充分、输入与环境前提适用，并且有对应的 supporting 引用。引用自身必须合法。观察内容中的单个状态字段不独立授权一张票。

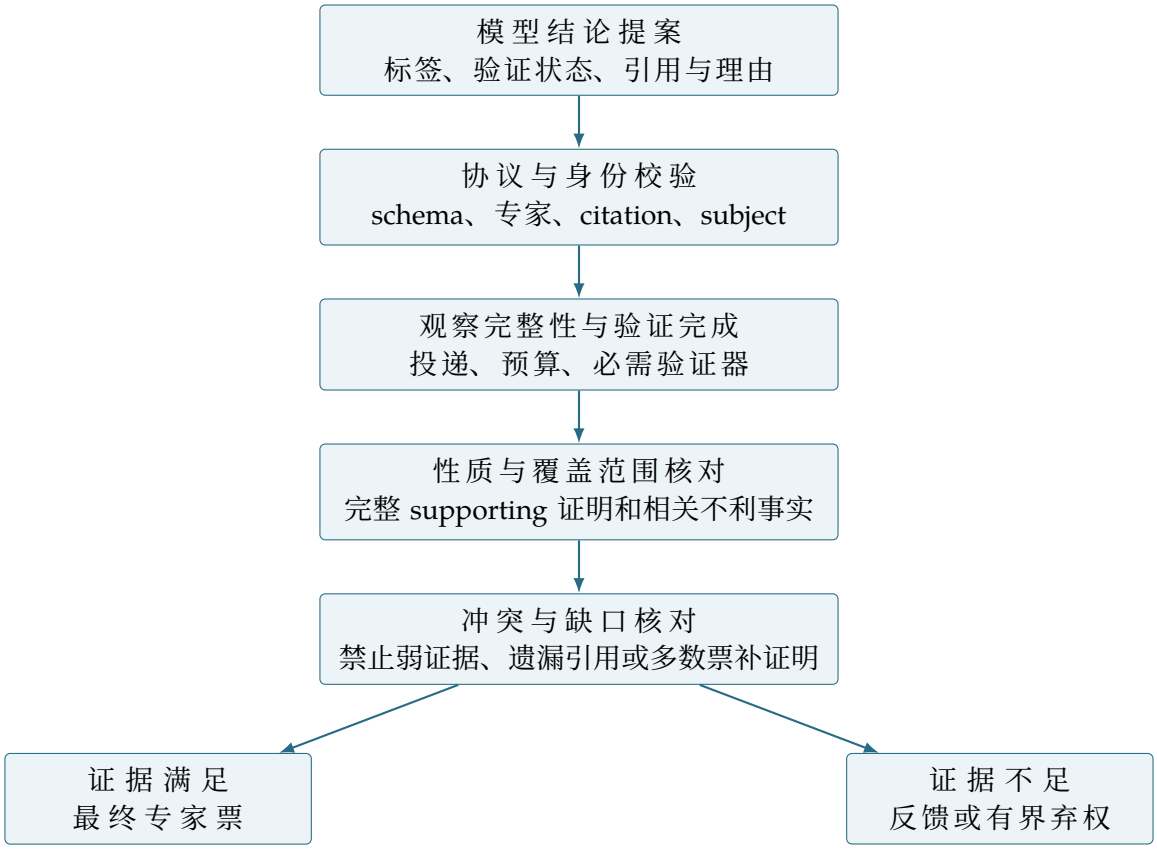


图 2: 准入阶段的逻辑层次。非法协议和身份错误显式终止，普通证据不足可进入有限纠正循环。

实现定位：`src/cv_agent/agents/evidence_policy.py`

8.2 supporting、counter 与 unresolved 的角色

最终结论分别保存 supporting、counter 和 unresolved observation IDs。counter 的含义是反对**当前预测标签**，而不是一般地反对漏洞假设。因此，对 SAFE 的肯定性安全证据应进入 supporting；把它放进 counter 并不能满足安全证明要求。

所有合法可见且候选绑定的相关事实都参加准入。省略不利观察、把它标成 counter/unresolved、改变 observation 的 citation 别名，或者增加一次只重复 sink 的静态扫描，都不能消除同范围约束。相同身份下相互不容的充分证明必须保留冲突并弃权。

8.3 静态事实与候选证明的门槛

观察	准入含义
源码阅读、sink 命中、sanitizer 名字	上下文或局部事实，不能单独支持候选确认。
`MAY_REACH`	可能数据流；没有证明完整来源、转换、路径和消费语义。
`NOT_ESTABLISHED` 或 `UNAVAILABLE`	尚未建立所需事实；不是安全或漏洞的否定证明。
完整候选命令危险路径	在性质、路径、前提和范围一致时，可支持实质预测。
所有相关路径的充分安全事实	还须排除相关未解析副作用与同范围冲突，才可支持 SAFE。
一个局部性质证明	只能支持对应的声明性质；文字 scope note 不能扩张实际证明范围。

表 7: 主要观察类型的准入解释。未知不会被重命名成证明。

充分危险路径和独立安全路径可以同时存在：只要某条完整危险路径满足前提，其他独立安全路径不抵消它。另一种情况是两个证明都声称覆盖同一完整范围，却得出互斥结论；此时不能采用状态优先级或只引用有利证明来消除冲突。

8.4 C1–C6 的规范职责

当前唯一语义规范入口是测试契约。[1]

表 8: 语义契约及其执行要求。

契约	主题	核心要求
C1	判断对象	候选、源码、位置、性质、范围及前提完整绑定；局部事实不升级为不匹配性质的证明。
C2	值与执行效果	区分已知值、来源、未知值，正常继续、终止、异常，及相关副作用与覆盖缺口。

契约	主题	核心要求
C3	求值顺序与摘要	短路、条件表达式、调用实参与 helper 服从同一副作用规则；摘要需要身份和输入前提。
C4	路径合并	完整危险路径、全范围安全、未解析路径、同范围冲突分别处理；重复条件关联不能制造假路径。
C5	证据准入	全部相关观察约束判决；调用顺序、引用角色和静态扫描增删不能替代语义事实。
C6	收尾与依赖	终止不降低证据门槛；任务结束不自动等于验证完成；非法协议不伪装成普通弃权。

9 静态分析器与类型化验证工具

9.1 命令分析的有界语义

命令分析器使用有限抽象值结构，包括字符串片段、有限 choice、来源及安全处理信息，并维护执行路径、绑定和副作用缺口。普通未知字符串与已经建立的输入来源不同；转义只在已经解析的消费上下文中有意义。

分析按 Python 求值顺序处理已支持的赋值、参数传递、有限分支与展开 helper。确定不能成功的解包不产生正常后继；有限备选同时包含成功和失败时保留成功路径；未知迭代协议保留可能相关副作用。未知对象的 truth、比较、属性访问，以及未知函数即使返回值未使用，也不能默认纯净。

整函数候选包含实际调用链中相关的操作。未经解析的前置调用可能改变后续值、绑定或可达性时，分析不能把后面的猜测 sink 当作完整危险链。独立、已经完整建立的危险链则不因另一条无关未解析路径而被删除。

`inspect_command_construction` 负责将分析事实封装成范围、来源、路径和缺口记录。该静态工具保留验证状态 UNRESOLVED；其完整分析事实可按准入规则支持特定预测，但不被描述为真实应用执行见证。

实现定位：`src/cv_agent/tools/analysis/commands.py;tools/validation/commands.py`

9.2 数据流与消费上下文

`trace_dataflow` 在已准入文档和调用图内追踪来源、sink、sanitizer、变量及调用参数绑定。Python 主链使用 AST 表达式和分支合并；其他语言包含有限逐行近似。工具返回可能到达或尚未建立，并保持 UNRESOLVED。

一个名称像 sanitizer 的调用并不证明防护有效。消费上下文改变、后续原始片段追加、解释器消费参数或输入、容器修改和未知转换，都需要重新核对。非 shell argv 和 shell 参数转义是不同的性质事实，不能仅凭 `shell=False` 字样给出宽范围 SAFE。

实现定位：`src/cv_agent/tools/analysis/python_flow.py;tools/analysis/sanitizers.py;tools/validation/dataflow.py`

9.3 权限 mode 验证

`validate_permission_mode` 对有界声明的 chmod mode 性质执行静态语义检查。受支持的常量和路径条件可以产生匹配的 CONFIRMED 或 REFUTED，但相关未解析副作用、绑定变化、未知对象协议和范围失配仍保持未决。

不同资源的权限设置不能彼此抵消；先宽后窄不能证明不存在时间窗口。一个明确调用的位模式证明不覆盖完整目录竞态，也不覆盖整个函数的授权安全。工具在产生实质状态时核对位置、输入前提和 `chmod-mode-others-write` 性质，消费端再次核对。

实现定位：`src/cv_agent/tools/validation/permissions.py`

9.4 动态求值的 AST 探针

`probe_python_eval` 是有界 AST 解释器的输入控制检查。它在准入的 Python 切片和调用跳数内处理有限参数、常量、局部赋值、分支与返回，具有 256 步解释上限。它不会执行仓库 Python、导入目标模块或调用任意宿主函数。

该工具需要确认具体输入到同一 builtin eval 参数的关系；builtin shadowing、未知外部调用、装饰器、参数展开或未支持构造保持 UNRESOLVED。CONFIRMED 是声明模型下的函数切片见证，不能被扩成完整应用执行或远程输入权限证明。

实现定位：`src/cv_agent/tools/analysis/python_probe.py;tools/validation/probes.py`

9.5 授权事实、差分与 registered fixtures

授权工具提取主体、动作、资源范围、ownership 比较和路由/服务守卫。参数名或不明上游策略不是具体授权证明；没有找到守卫不等于已建立绕过。源码 diff 可以描述两版变更，不能自行确认漏洞或补丁安全。

registered fixture 声明其 subject 和 proof scope，包括性质、candidate/local 覆盖、方法和支持的状态。`source_pattern` 方法不能作为充分候选 fixture 证明。一个不匹配的 fixture、另一个 helper 的结果，或者固定 token 夹具的成功，都不能通过通用 CONFIRMED 字段证明任意性质。

项目自有 loopback HTTP 验证比较已声明的授权与未授权响应，且只适配相应 `authorization-boundary` 范围。HTTP 状态码不能被注册者文字声明成命令执行或权限证明。其驱动禁用代理与重定向，应用回调置于受限子进程，网络仅保留预绑定本地 listener。

实现定位：`src/cv_agent/tools/validation/authorization.py;tools/validation/comparison.py;tools/validation/fixtures.py`

9.6 执行隔离的适用假设

受控 fixture 和 witness 使用可抛弃的 Linux 子进程，配置有限资源、截止时间、文件描述符及系统调用、文件系统访问约束；隔离不可用时拒绝执行。文件读取需要显式 read roots 或身份绑定的叶子准入；目标侧文件系统写入被禁止。

这些边界为项目拥有、明确注册的有界验证服务提供控制。源码索引、AST 探针、registered callback 与真实目标 worker 具有不同执行模型，不能笼统把它们都称为在同一个通用沙箱里运行。模型接口始终只提出 schema 允许的数据与工具调用。

实现定位：`src/cv_agent/runtime/fixture_isolation.py;runtime/fixture_syscalls.py;runtime/witness/isolation_policy.py`

10 源码绑定的正向执行见证

10.1 为什么需要单独的见证接口

静态分析遇到复杂下载、框架分派、对象状态和 helper 副作用时，扩大解释器覆盖面没有自然终点。执行见证选择另一种受限能力：固定一个已经定位的候选和一组完整分类前提，执行真实源码，核对是否在该条件下出现预期的命令消费事实。

工具名为 `run_bounded_execution_witness`，proof contract 为 `bounded-execution-witness-v1`，性质固定为 `command-execution`，支持状态只有 CONFIRMED。未达到确认条件时返回具体 gap 和 UNRESOLVED。它不提供 REFUTED，也不通过有限次未观察到展开来输出 SAFE。

实现定位：`src/cv_agent/tools/validation/bounded_witness.py;runtime/witness/contract.py`

10.2 清单、执行上下文与准备状态

系统从源码、subject 和可信 execution context 构造 `WitnessManifest`。清单包含入口及调用方式、参数、构造数据、输入位置、分类场景、解释器、目标模块库存、资源配置、对照和受控记录信息。

`WitnessExecutionContext` 承载 checkout、解释器、读取准入、资源和响应方式。模型不能替换这些运行时控制，也不能选择源码摘要、内核策略或证明义务。模型只能按照工具指出的缺失字段补充数据型调用信息。

缺字段时输出 `ValidationPreparation`，明确 `witness_attempted=false`、缺失字段名、目的位置、是否需要分类及继续动作。准备状态不算验证完成。对已有 dataset 场景，工具要求保留声明场景；对空场景候选，模型提出完整分类假设后才可进入执行。

实现定位：`src/cv_agent/tools/validation/witness_manifest.py;domain/validation_protocol.py`

10.3 分类场景与双 subject

每条前提包含值、分类和 rationale。分类为攻击者可控输入、部署配置或环境条件。输入参数、布尔开关、条件、值、构造数据和预置文件均使用有界数据 schema；布尔值是严格 JSON 布尔，字符串形式的布尔不能冒充真实布尔。

系统保存原始 subject，另生成 **execution subject** 表示这次场景条件。场景来源和规范 JSON 摘要分别记录。模型假设不能改写原候选身份，不能与未分类外层数据混用，也不能覆盖已有数据集场景。数据集自带的旧场景同样需要可信分类记录才能执行。

分类描述“需要谁控制哪些输入或配置”，没有证明现实部署中的远程调用权限。完整运行时核验仍要验证值、分支、构造对象及预置数据实际满足声明。当前原始观察明确保存 `remote_authority_established=false`。

实现定位：`src/cv_agent/tools/validation/witness_scenario.py;runtime/witness/scenario_runtime.py`

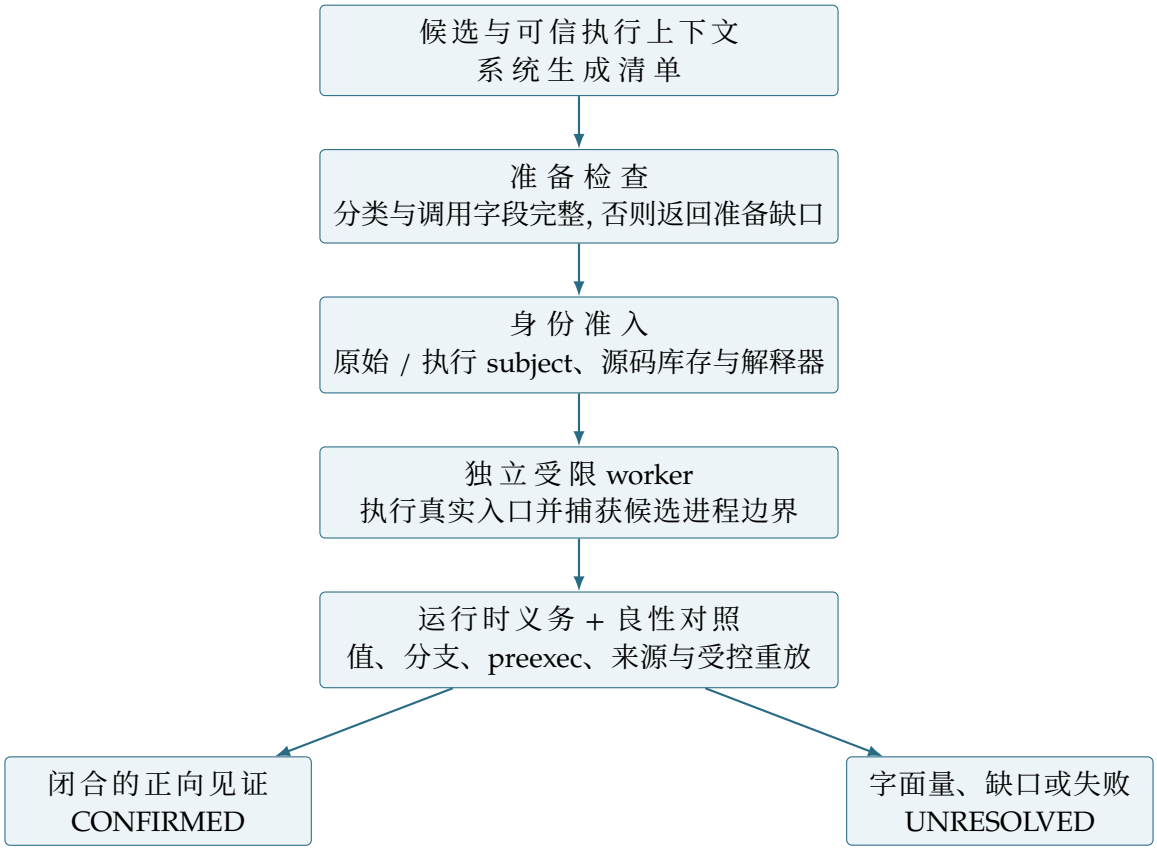


图 3: 正向见证的条件执行链。每个结果同时保存其场景来源和未覆盖范围。

10.4 真实目标、候选帧与源码库存

内核在独立解释器中运行目标入口，使用受控观测捕获首个相应命令事件，核对真实 `subprocess.Popen`、候选与 emitter 帧、入口源码、加载模块和解释器。目标命令事件受到拦截；解释语义由独立的受限重放检查，不直接运行模型任意命令。

开发配对每侧绑定 977 项源码模块。入口文件文本相同不意味着两版完整执行源码相同，差异可以位于被调用 helper；因此必须对每一侧自己的库存与此前绑定作比较，不能用“两侧入口一样”代替迁移前后身份一致。

未认证的边界、加载源码漂移、候选帧未到达、记录器条件未满足、隔离失败或环境问题，都返回具体缺口，不能被工具封装或模型理由补齐。

实现定位：`src/cv_agent/runtime/witness/kernel.py;runtime/witness/contract.py`

10.5 运行时义务的四类检查

已验收开发控制包含九项义务：三项值、四项条件、preexec 实跑和良性对照。这个数字属于已选开发场景，而不是任意新候选的固定九项配额。[8]

表 9: 见证义务及其需要排除的误解释。

类别	核验内容
值	在匹配源码与入口状态下核对实际实例/模块值及其类型；避免名称猜测、隐式对象协议或外部声明代替值事实。
条件	通过完整规范 AST 绑定条件出现处，观测实际执行分支；不重新 eval 模型给出的表达式，不能用子串匹配代替分支测量。
preexec	对真正绑定的对象在受限子进程中验证正常返回、退出状态和禁止事件；仅凭函数名字不认为其纯净。
良性对照	与测试输入保持已声明环境一致，核对控制输入的保留及受控重放；对照失败使正向确认不成立。

条件监控还记录源码摘要和实际指令位置，监控占用或篡改属于缺口。preexec 新加载源码、异常、非正常返回或隐藏操作也保留为未解析。工具的 scope note 根据实际到达及义务核验生成，准备假设不会被措辞改写成已证事实。

实现定位：`src/cv_agent/runtime/witness/obligations/values.py;runtime/witness/obligations/branches.py;runtime/witness/obligations/preexec.py`

10.6 入口适配与环境准备

见证支持受约束的普通函数、方法及精确绑定的 Click callback。直接 callback 调用不执行公开 CLI parser，因而没有证明公开参数转换、命令分派或部署调用权限。callback 的限定范围保留在响应中。

K3 环境准备对 commit、Python 版本、锁定依赖、目标 wheel 和运行时 requirements 作显式校验。目标包只安装 metadata，从干净 checkout 导入目标源码，避免 site-packages 中另一份源码替代被审查快照。环境报告保存依赖版本、库存、导入与 kernel bootstrap 结果、读取诊断及准入提案。

读取提案和接受的读取准入分别保存。默认不会把新诊断提案自动生效，也不会对广泛目录开放读取。已核验开发环境每侧 141 个包、977 项源码绑定，沿用四个身份绑定的叶子准入；七个未接受读取提案仍保留。目标导入或 bootstrap 失败，以及结构性追踪缺口，阻止 context loading。

K3 历史准备中存在按原授权、固定索引和 hash locks 进行的联网依赖准备，后来两侧均能以 cache-only、`allow_network=false` 重建。它们属于环境准备请求，不是模型请求；不能把 K2 收尾“无联网”的范围扩到项目全部历史准备。[11]

实现定位：`src/cv_agent/runtime/witness_entry.py;evaluation/preparation/prepare_witness_environment.py;evaluation/preparation/witness_import_worker.py`

10.7 资源配置与可复现环境

资源 profile 包含 CPU soft/hard、地址空间、文件大小、文件描述符和 wall-time。固定 fixture 默认和由测量推导的诊断 profile 分开；软硬限额、序列化字段和实际已安装资源限制都要检查。

开发环境的导入基线采用 CPU 15/20 秒、地址空间 2 GiB、64 个文件描述符、30 秒 wall-time。记录中的配对见证约 15–16 秒墙钟，每个 worker 约 8 秒 CPU、170 MiB 峰值 RSS。这是少量开发观测的资源画像，不是任意目标的固定性能承诺。

目标自身原生扩展的源码构建尚未被当前 metadata-only 准备覆盖。公开入口若需要可写临时目录，也会被现有只读隔离阻止。context 的 import ready 不保证所有分支可执行；分支和见证仍需单独检查。

实现定位：`src/cv_agent/runtime/witness_resources.py;runtime/witness/accounting.py;runtime/witness/tracer.py`

10.8 compact 投递与私有完整产物

见证可以使用紧凑投递，在模型响应中保留规范场景引用、摘要、状态、缺口、有限命令观测及范围说明，而完整 subject、清单、前提理由和 worker/control/replay 记录保存在私有产物。

compact 是投递表示，不是弱化证明的捷径。分类不完整、摘要缺失或范围错误时拒绝压缩；如果完整外层序列化响应仍被裁剪，确认资格不能保留。生产者完整结果同时进入可靠性遥测，使隐藏或失败投递中的固定侧误确认仍能触发停止条件。

实现定位：`src/cv_agent/tools/validation/witness_response.py;tools/validation/bounded_witness.py`

11 Jev 分流与政策组合

11.1 定位与传输契约

Jev 用于选择验证动作或规划补丁，输出 scheduling decision，不输出专家票或漏洞证据。该协议通过同一 `OpenAICompatibleChatModel` 和完整测试门禁传输，记录其自身模型 ID、请求、usage 和延迟。

结构化请求提供 state 和有限 choice questions；响应为每个问题的 choice、概率分布与 provider confidence。分布需包含全部声明选项、概率有限且处于区间内、总和近似为 1、被选选项为最大概率项。决定采用与否使用被选项概率，而 provider confidence 另行记录。

实现定位：`src/cv_agent/runtime/jev.py;agents/routing.py::decide_validator`

11.2 off、shadow、active 与版本差异

off 不发 routing 请求；shadow 记录决策但不改执行；active 可在符合政策时应用任务选择。历史 V2 配置将门槛声明为 0.85，实际运行必须使用自身配置的概率门槛，不能把不同版本视为同一消融臂。

V3 先锁定确定性必需任务，再让 Jev 选择可选验证。未覆盖部分只允许 scoped planner patch，不回退为不受约束的整份新计划。一个决定“被接受”与“实际应用”是两个状态，结果分别记录 accepted、applied 和理由。判断 routing 是否节省规划请求，必须检查实际 planner 调用和 applied 状态，不能仅凭最终标签正确。

独立 `E4_RULE_V1` 只使用政策任务构造计划，不调用规划模型。它用于区分政策覆盖与 routing 增量；即使计划完整，最终实质票依然需要同一证据门槛。历史 Jev 六格弃权不能当作当前有界见证的成功实验。

实现定位：`src/cv_agent/agents/routing.py::route_plan_v3;agents/workflow.py::_plan;agents/workflow.py::_plan_patch`

12 最终投票、早停与共享观察

12.1 单票与 quorum 规则

E1–E3 使用单张最终 scan 票。E4/E5 默认 quorum 为 2，ABSTAIN 不计入实质标签票数，重复专家票直接拒绝。设 n_V, n_S 分别为两类实质票数，在默认三专家设置下，最终规则可写为

$$\hat{y} = \begin{cases} \text{VULNERABLE}, & n_V \geq 2, \\ \text{SAFE}, & n_S \geq 2, \\ \text{ABSTAIN}, & \text{其他情况}. \end{cases} \tag{8}$$

两张相互冲突票加一张弃权不形成 quorum；一张 CONFIRMED 票也不会因为验证状态强而产生额外票。输出 confidence 是被选标签专家 confidence 的算术平均，不是经校准的正确概率。

实现定位：`src/cv_agent/agents/voting.py`

12.2 E5 的提前终止保证

E5 在声明顺序中前两名专家的**最终**票均形成后尝试早停，并检查未完成必需依赖。若两张通过准入的实质票同标签且达到配置阈值，第三张票无法改变默认三票多数标签，因而可以输出 fast；否则继续 slow。

当前通用 `fast_confidence` 默认值为 0.0，实际“高置信”约束取决于显式 profile，不能从旧叙述推断默认已经采用较高门槛。固定票序列的标签不变性有有限组合测试，但真实模型改变任务调度后可能生成不同响应，故回放一致性不证明独立 live E5 与 E4 总是同标签或低成本。

早停前已经执行的全部任务都计入成本，包括已经开始的其他专家任务。被阻塞必

需任务不能被 fast 掩盖。多数机制提供受约束聚合，不具有分布式故障共识的协议保证，也不证明多票来自统计独立证据。

12.3 共享票与原始观察计数

K4 引入两个明确字段：

- `material_votes_sharing_validator_observation`：引用同一充分原始验证观察的共享最终实质票数。
- `independent_validator_observations`：不同原始生产者观察数，名称中的 independent 不表示统计独立。

原始生产者身份是 task execution ordinal 与 trace step ordinal。citation 别名、跨任务引用和累积轨迹副本映射回原始观察；manifest 或场景摘要标识内容，不标识某一次执行，因此相同 manifest 的两次物理执行不能被误合并。

准备、未解析、失败、截断、抑制及私有未投递遥测都不能增加证明票数。K4 的开发 a 控制由 scan 和 taint 解读同一见证形成两票，计为共享票 2、原始观察 1。它验证共享记账正确，没有建立两份独立见证。[12]

实现定位：`src/cv_agent/agents/validator_accounting.py;domain/review.py::AgenticVerdict`

13 模型传输、日志与实验预算

13.1 所有真实模型调用的唯一准入链

live 模型经 `OpenAICompatibleChatModel.complete` 进入测试门禁，然后生成 request ID、记录 model start、发出请求、记录原始响应与 usage、解析 reply 并记录成功或错误。scripted 模型用于确定性离线机制检查，运行 provenance 由实际模型类型核验，不能通过文字字段伪装为 live。

同一进程首次真实请求前自动运行完整 `uvrun--no-syncpytest`。指纹覆盖 src、tests、scripts、configs、validation 以及依赖声明、AGENTS 和测试契约。当前完整门禁有 900 秒有限截止时间。进程启动后、测试期间或准入后源码指纹变化，都阻止继续请求。

通过状态只保存在该进程内存；本地 gate log 是审计产物，不是可重复使用的 pass stamp。测试失败后该进程不按剩余 trial 自动重复尝试准入。发请求需要实际配置中的实验授权，测试通过本身不授权新增预算、provider fallback 或重跑。

实现定位：`src/cv_agent/runtime/model.py;runtime/admission.py`

13.2 测试隔离与凭据处理

门禁子进程清除 API key、token、secret、password 等凭据环境项，禁用自动 pytest plugin 加载，并移除会改变测试选择或 provider 的部分环境设置。pytest 使用 scripted 模型、mock HTTP 及项目拥有的 loopback 夹具。

真实模型的 endpoint、model、temperature、超时及输出上限由显式运行配置与提供商组装获得，凭据在运行入口加载。模型响应记录对当前配置的 API 密钥值脱敏；源码归档和技术报告不保存凭据。模型 ID 使用实际返回值校核，不能仅凭请求配置名字认定上游实际模型。

实现定位：`src/cv_agent/runtime/provider.py;runtime/model.py::_record_response`

13.3 先记录 usage，再验证响应内容

模型原始响应中的 usage 在 content、tool JSON 或最终 reply schema 校验前写入日志。因此，格式错误且具有 reported usage 的响应仍计入成本。请求数在 model start 计数；无响应、解析失败和中断都不被解释为零请求。

事件按 request ID 对账，检查重复 start、孤立响应、usage 冲突、缺失 reported usage 和无效响应。未知 usage 与未配置价格不等于数值零；只有所有相关分量已知时，才能给出完整总和。报告使用 provider reported tokens，而文本字节预算单独报告。

HTTP 错误、空 choices、非法工具 JSON 和超时显式失败，不作为 SAFE 票。当前传输不会因这种失败自动换 provider 或执行静默重试；若协议允许的纠正循环再发请求，该请求必须重新进入预算与记账链。

13.4 耐久事件与全局停止

Journal 按 JSONL 追加事件，flush 并 fsync 后才继续操作。并发实验使用锁保护日志和预算，单个 trial 保存模型、工具、角色、调用参数、允许工具与准入路径等。结果同时保留原始轨迹和纯汇总，异常不会抹去此前请求。

通用 Budget 约束请求数和 wall-time，LockedBudget 约束共享并发。场景实验另有累计 token 账本、阶段上限、保守 reservation 和硬停止条件。实验取消阻止后续请求进入；线程任务的实际已发生操作仍须入账。

源码快照、配置、provider 参数、gate log、事件、结果、usage、summary 和验收形成可审计产物链。fingerprint 与归档按已授权边界机械读取文件，不能被当作检测语义访问或用来恢复模型可见标签。

实现定位：`src/cv_agent/runtime/journal.py;runtime/budget.py;runtime/snapshots.py;evaluation/experiment_guard.py`

14 评价层、配置组合与实验生命周期

14.1 配置按职责组合

配置目录按 models、datasets、profiles、experiments、preparation、diagnostics 与 history 分类。dataset 声明样本、角色、来源和前提；profile 声明系统、预算、检索、选择格子和预登记弃权；model 配置声明模型默认参数。专项实验维持自身明确的类型化配置。

advisory 数据与运行 profile 经 `compose_advisory_config` 组装成既有类型化协议，字段不能任意交叉覆盖，缺失或无效配置直接报错。解析后的完整配置进入 metadata。文件名中的历史模型名不能替代实际返回模型 ID；含 heldout 字样的旧路径也不能恢复数据盲测资格。

旧配置和历史产物被保留用于版本比较。迁移等价性测试核对明确路径替换与新增字段，不能通过覆盖旧结果来制造一致。准备程序具有修改数据的行为；查看项目架构不授权重建数据或开启实验。

实现定位：`src/cv_agent/evaluation/datasets/composition.py;evaluation/datasets/advisory_config.py;runtime/provider.py`

14.2 候选执行与结果状态

`run_candidate` 组装 index、candidate、系统、模型、记录工具和预算，调用 `AgenticPipeline.run`。结果为实质判决时记为 completed，为合法弃权时记为 abstained；传输、schema、内部异常或超时有明确 failed/interrupted/not-run 状态。

尚未发送模型请求就被预算阻止，可以记为 not-run；已经发生请求后失败，仍保存请求和工具尝试计数。中断会记录当前结果与时长再传播，不能在汇总中当作没有运行。所有实际执行任务包含在最终模型和工具成本中。

实现定位：`src/cv_agent/evaluation/execution.py;evaluation/results.py`

14.3 实验生命周期

advisory 生命周期先校验配置、模型和数据准备，创建独立 run 目录、源码与配置快照及耐久事件，再按预登记的格子顺序或显式并发执行任务。每格结果增量保留，结束或停止后由纯汇总逻辑输出 usage、summary、acceptance 等文件。

不同 protocol 按各自样本前提检查验收：开发门禁可声明有意弃权；配对检查良性功能保留及预期拒绝；场景实验分别审计 dataset、model 和 developer-scripted 来源。通用测试通过不意味着这些专项前置条件已经满足。

源码发现 runner 的 checkpoint 保存清单身份、源码分析指纹、已完成提交和解析错误。恢复需要相同 detector manifest、数据身份和代码指纹；不兼容状态拒绝恢复。临时 worktree 用于减少同时保存大量完整 checkout 的空间压力，原始候选清单和哈希继续保留。

实现定位：`src/cv_agent/evaluation/lifecycle.py;evaluation/runners/run_vulngym_discovery.py;evaluation/repository.py`

14.4 检测输入与评价标签分离

一般仓库输入可以只包含 repository URL 和 commit；候选定位及性质应由检测流程产生。评价侧 reference 含标签、关键位置和人工核验信息，只有在候选或 findings 已产生后才参与匹配与计分。oracle-diagnostic 使用已知入口作为 seed 时，必须明确其角色，不能报告端到端发现召回。

当前源码发现 evaluator 按规范化仓库、commit、路径和行号精确匹配 critical-operation 位置。旧目标规格中出现的其他行号容忍窗口，不自动成为该实际计分器规则。没有核验负例的正例参考集不能估计 FPR；未匹配的 VULNERABLE finding 也不能仅凭参考表缺项判为假阳性。

开发样本、已暴露的公告路径或 oracle-seeded 数据保持 `claim_eligible=false`。架构方披露已查询部分 held-out 评价侧元数据，VulnGym v4 的命令注入相关结论、Python 类别组成和语言组成不再视为盲测。技术报告仅引用已归档披露，不重新读取受保护输入或 evaluator 标签。[19]

根目录 `.ignore` 使 ripgrep 默认搜索跳过受保护输入及其源码快照副本；它是默认导航的预防措施，门禁指纹和源码归档继续按独立规则机械读取。搜索排除规则不应被误写成文件本身已经删除或无法被显式访问。

14.5 运行完整性与研究 claim readiness

`assess_run_readiness` 对 acceptance、metadata、summary、usage 及结果/事件中的 fixture 使用作交叉核对。它不只读取一个存储的 passed 布尔。

关口	实际含义
完整 pytest	当前代码可进入受门禁约束的实验；未证明检测效果。
专项 acceptance	本次 run 满足其预登记的具体验收标准；未自动满足独立研究条件。
`operational_ready`	运行产物和请求记录足够完整且专项验收没有运行阻断。
`claim_ready`	在 operational ready 之上，还需合格 final 角色、显式 claim eligible、干净记账和独立评价前提。

表 10: 主要验收关口。不同层级分别记录与报告。

有 trusted fixture 替代独立评价、数据角色非 final、usage 冲突或缺失、解析错误等情况会影响对应关口。当前开发门禁即使全部通过，也不会把 `claim_eligible=false` 自动改为 true。

实现定位：`src/cv_agent/evaluation/protocols/readiness.py;harness/validation.py`

15 三值评价指标与成本归因

15.1 保留完整分母

设全部评价项数为 N，实际正例与负例数为 N_+, N_-；已完成实质判断的混淆计数为 TP, FP, TN, FN。弃权、失败、中断和未运行作为独立计数保留，而不伪装成正常

SAFE 或从总体分母删除。当前主要指标为

$$\text{Coverage} = \frac{TP + FP + TN + FN}{N}, \tag{9}$$

$$\text{StrictRecall} = \frac{TP}{N_+}, \qquad \text{CoveredRecall} = \frac{TP}{TP + FN}, \tag{10}$$

$$\text{Precision} = \frac{TP}{TP + FP}, \tag{11}$$

$$\text{PopulationFPR} = \frac{FP}{N_-}, \qquad \text{CoveredFPR} = \frac{FP}{FP + TN}, \tag{12}$$

$$\text{ConservativeFPR} = \frac{N_- - TN}{N_-}, \tag{13}$$

$$\text{Accuracy}_{\text{all}} = \frac{TP + TN}{N}. \tag{14}$$

分母为零时返回未定义值。严格召回和全量 accuracy 保留未覆盖项影响；covered 指标回答已经形成实质结论的子集表现。保守 FPR 将所有未证成真阴性的负例计入保守记分，应与真实观测 FP 分开解释。

部分源码发现计分只具有正例参考，因此 FPR 明确为未定义。配对的真假标签判断、关键位置发现命中、advisory 召回、具备匹配 validator 的票数，以及实际执行见证次数，都有不同分母，不能互相替换。

实现定位：`src/cv_agent/evaluation/metrics.py;evaluation/discovery.py;harness/results.py`

15.2 区间与配对比较

metrics 模块提供描述性的 Wilson 二项区间，并明确它不是跨仓库泛化区间。缺失项、中断或未完成的 provisional 结果保留标识，不能通过只挑完整格子来制造确定性结论。

配对统计按 case 与 system 对齐，记录左赢、右赢、相同、不可用及标签分歧。案例和同仓库多个入口具有相关性；单轮开发对照没有自动获得重复实验或仓库级独立样本的解释权。显著成本或召回改进需要另行冻结重复次数、统计单位和分析规则。

15.3 成本的三个维度

上下文成本记录检索和观察的序列化文本上界；**模型成本**记录实际请求与 provider reported usage；**执行成本**记录工具尝试、物理 witness、资源和墙钟。三者在结果中共存，而不是把一个工具观察单位换算成一个 provider token。

E5 固定票回放可计算哪些后续任务会被跳过，但该值是反事实节省，未测量新调度下模型回复、工具耗时或总 wall-time。Jev 也需要将 routing 请求、source read 和 scoped planner 成本计入总额；最终标签正确不单独证明 routing 已采用或节省了请求。

16 当前验收记录、实验观察与正式决策

16.1 K1–K4 的工程结果

表 11: 截至 2026-09-30 的工程结果与有效解释。

工作	完成内容	有效解释与限制
K1	见证范围与分类前提投递	准备与实际执行说明来自测量状态；保留给定场景 a 确认、b 未决控制。
K2	运行时迁入 `runtime/witness/`	九个迁移模块的 import 归一化文本及 AST 相同；每侧 977 项源码库存、两类 subject 与结果前后相同。
K3	源码绑定环境从头重建	两套 Python 3.12 环境，每侧 141 个依赖版本与 977 项源码绑定一致，未新增读取准入。
K4	E4 共享观察与票数验收	a 为两张实质票共享一次见证；b 为弃权。E5 用固定票回放，额外实际见证为零。

K2 验收中，a 为 `CONFIRMED/EXPANDED_OBSERVED`，b 为 `UNRESOLVED/LITERAL_OBSERVED`；manifest 唯一变化字段为重建 venv 的 `python_executable`。完整 K2 suite 为 2562 passed / 433.32 秒；最终工作树历史日志另记 2562 passed / 400.78 秒，harness 均为 PASS。本文引用这些既有日志，没有新跑测试或沿用 pass stamp 发请求。[10, 16]

这些真实源码 worker 是 developer-scripted 驱动的控制。其工具 provenance 可记录 model-proposed 数据接口，但实验来源仍是给定脚本，不能计为真实模型自主提出成功。

16.2 M0 与 E-iter 的调用账本

范围	实际请求	Reported tokens	观察
M0 阶段 1	32	191177	A/B 四格全部弃权；B-a 未完成准备。
M0 阶段 2	14	90153	唯一一次 B 两格重跑；实际执行后仍未确认。
追加 E-iter	26	166482	四格全部弃权，未发生模型驱动的第二场景执行。
本轮共享账本累计	72	447812	低于 210 请求、2500000 reported tokens 上限。

表 12: 统计范围限定为 M0 与追加 E-iter 的共享授权账本。此前历史实验在各自档案中分别保留。

E-iter 的 26 次返回模型 ID 全部为 `deepseek-flash`，每次响应具有 usage，原始日志与独立审计一致。真实调用前新进程门禁为 2556 passed / 390.51 秒。每格只有一

E-iter 格子	请求	Tokens	执行次数	人工复核的主要缺口
开发见证 a	6	36234	1	F3，场景选择不满足目标见证条件。
开发见证 b	7	44985	1	同一分支与记录前缀缺口；最终弃权。
近迁移 callback a	7	45465	1	F4，临时目录不可用，尚未到进程边界。
近迁移 callback b	6	39798	1	同一隔离/临时目录限制。

表 13: E-iter 四格结果。运行标识分别对应 hp003_a/b 与 hp004_a/b；后一对为 entry-00390 的近迁移。

次物理场景；两份原始 VULNERABLE/UNRESOLVED 提案被准入拒绝，最终四格均 ABSTAIN。固定侧没有 SAFE、producer CONFIRMED 或已准入 VULNERABLE。[15]

开发 a/b 场景选择仍落入不同于目标见证的分支，完整紧凑响应已到达模型，后续动作没有形成第二场景尝试。callback 两格在目标候选帧前被隔离环境的临时目录创建阻断，应归因基础设施 F4，不能计成场景选择能力失败或补丁安全。

16.3 失败分类与归因规则

类别	预登记解释
F1	未调用见证工具，或未走完准备/工具协议。
F2	场景假设多次被输入 schema 拒绝。
F3	场景被接受但不足以形成所需见证；必须列出实际缺口。
F4	见证基础设施、隔离、资源或超时问题。
F5	见证已确认，但 agent 的最终判定未接纳对应正向证据。
F6	局部或累计预算耗尽。

表 14: M0 失败分类。自动诊断与人工复核分别保留，类别可以具有伴随因素。

阶段 1 B-a 的主因是 F1；阶段 2 B-a 主因为 F3，局部 F6 伴随。E-iter 并没有完成模型自主迭代。离线脚本证明工具和原预算可以容纳两个不同场景，不证明真实模型会利用这一能力；提示、协议和投递共同变化的一轮探索也不能隔离预算的因果作用。

16.4 近迁移、外部样本与 G-A

3a 的 callback 与原开发样本来自同一 advisory，只是入口近迁移，不是外部项目迁移。离线正确脚本也在临时目录创建处失败，因此 M0 原 3a 的模型运行未满足前置条件；追加 E-iter 包含这两格来自单独授权，不追溯修改原阶段规则。

3b 按预登记顺序冻结前 15 条公告，没有继续从第 16 条挑选。唯一符合源码路径标准的暂定外部候选缺少对应源码版本的目标原生扩展，环境标准未满足，合格外部对数为 0；没有新增 v7、脚本确认或该阶段模型请求。该事实描述当前环境准备能力，没有证明该源码不可构建。

正式 G-A 使用合取条件

$$GA = (\text{原 M0 的 B-a 自主成功}) \wedge (\text{3b 至少一对外部迁移成功}). \tag{15}$$

两项都不满足，故 G-A = NO。developer-scripted 控制、3a 近迁移和追加 E-iter 不参与救回原门槛。K5–K8 未启动；未使用预算也不构成重新启动这些工作的授权。[17]

17 测试体系、回归要求与有效覆盖

17.1 验证方法

所有代码变更必须通过完整 `uvrun--no-syncpytest` 后才可进行真实模型实验。针对已复现语义缺陷，先增加失败行为回归和正控制，再修实现，最后运行完整套件。单个 targeted pass 不是 live 准入。

测试使用临时源码、scripted 模型、mock 传输及项目自有 loopback fixture。Linux Java 边界测试使用固定项目夹具、JDK 的编译能力及 C 编译器，不以下载完整外部 Benchmark 或读取真实凭据为前提。可选真实 checkout 测试可能因环境缺失跳过；普通 pytest 成功不证明该外部配对的运行前提已具备。

17.2 T01–T16 的主链验收类别

表 15: 测试契约要求的验收类别。当前主链核验不表示所有组合已穷尽。

类别	检查主题	关键行为与正控制
T01	caller/helper 范围	不借 helper 局部安全抵消 caller 危险；双方受支持安全时仍保留安全判断。
T02	位置与切片	不同 sink、偏移、装饰器及 helper 不错借身份；准确位置正例可通过。
T03	表达式副作用	条件、短路、比较、海象和参数位置的相关操作被保留或明确未解析。
T04	纯度与死分支	确定死分支和未调用延迟体不虚构执行；未知对象协议不默认纯净。
T05	helper 执行效果	参数、别名、全局和函数重绑定缺口不被未使用返回值抹去；独立完整危险事实保留。
T06	解包与终止	全成功、全失败、成功与失败/未知组合、嵌套及异常边界保持正确后继。
T07	输入来源	未知值不等于已证明输入；错来源不套用摘要；具体前提保持正例。
T08	消费上下文	正常保护、后续拼接、二次解释与非 shell 消费区别处理。

类别	检查主题	关键行为与正控制
T09	条件关联	相同条件重复检查不生成不可能路径；绑定改变和未声明平台保持缺口。
T10	权限覆盖	不同目标和时间顺序不抵消；位模式证明不升级为竞态证明。
T11	引用与取证不变性	角色、省略、静态扫描和独立读取顺序不能改变同一语义事实的约束。
T12	路径和证明冲突	不同独立路径与同范围互斥证明分别处理；真实危险路径正例仍可用。
T13	身份与投递	完整且匹配的证明可用；错 subject、性质、摘要、引用及裁剪/抑制/错误被拒。
T14	收尾和用量	普通与末步阶段同一证据门槛，零尝试不伪造成票，全部实际请求记账。
T15	验证完成与依赖	未完成必需验证器阻塞直接和传递依赖；已完成未决与未完成分别记录。
T16	多任务与 quorum	同一专家一票，弱票不能凑证明，固定票早停与全量标签一致。

[1]

当前契约文末记录了上述主链的逐项复核与仍未支持的边界，早期表格中的阻断描述保留为历史，不作为当前未修复状态。测试数量本身不决定 Python 语义完备性。完整异常分析、动态下载/插件分派、任意对象协议以及远程权限仍不能由现有用例外推。

17.3 关键测试入口

`test_live_gate.py` 检查完整测试准入、失败与指纹变化以及传输隔离；`test_witness_runtime_boundary.py` 检查 K2 分层；`test_evidence_validation.py` 与候选身份测试检查准入和投递；`test_agentic_workflow.py`、`test_react_engine.py` 和 quorum 用例检查依赖、恢复、单票和收尾。

见证测试组覆盖清单绑定、实际候选帧、值与分支义务、preexec、worker 清理、资源、compact 响应和环境准备；共享计数测试覆盖 alias、相同 manifest 的不同物理执行及字面量误用。归档证明用于追溯既有行为，每次新增 live 进程仍重新完整准入。

18 能力边界与后续设计

18.1 当前可以依赖的能力

在已声明源码和性质范围内，系统可以组织有界上下文、类型化取证、可审计 ReAct 与依赖调度，并拒绝已知的错范围证明、弱静态确认和错误安全推断。源码绑定的开发

配对控制可以在给定分类场景下重复产生 a 确认与 b 未决结果。K2 已确认运行时迁移未改变该有界行为。

这些结果支持工具机制和已枚举范围的验收。它们不包含真实模型自主确认成功率、独立外部迁移率或 fresh held-out 检出率。合法弃权表明某项证据门槛未满足，不能仅从弃权比例评价整个工具没有分析信息。

18.2 当前限制及原因

表 16: 当前限制与测量依据。

限制	实际影响
场景提出	真实模型在本轮没有完成自主确认；反馈后没有主动迭代到第二物理场景。
静态语义	部分 helper、动态分派、外部转换与对象协议保持未解析，不能给出全应用证明。
入口覆盖	直接 callback 不包含公开 CLI parser；本地调用条件不能替代远程权限。
文件系统隔离	执行路径需要创建临时目录时可能在 sink 前失败；失败属于环境边界。
目标原生扩展	metadata-only 准备没有构建目标自身 native 代码，外部样本因此无法完成当前环境准入。
多专家证据	多票可能共享一份原始见证；统计独立性和真实模型早停成本没有由该共享控制建立。
数据与 claim	开发、oracle 和已暴露元数据的范围不能支持盲测泛化；需要新的冻结评测。

18.3 已列出的扩展选项

定位报告列出四类后续工作，均处于需要新的决定与预登记的状态：

1. 隔离内限定于 worker 的私有临时目录，同时保留其他位置的写入禁止正反控制。
2. hash 锁定的目标原生扩展源码构建，并保存构建产物与源码身份。
3. 单独研究场景提出与失败反馈后的迭代，预先规定预算、重复次数和成功标准。
4. 在前述能力得到正向结果后，构建事前冻结的新鲜评测集，确定样本、日期和评价单位。

架构 K5 的入口提升、K6 仓库级端到端、K7 稳定性和 K8 新鲜评价尚未启动。技术报告保留这些设计依赖，用于解释扩展路线，不把它们列作现有系统已经实现的能力。[18, 14]

19 报告的复现与来源管理

19.1 文档构建

本报告是单文件 LaTeX，图形由 TikZ 生成，没有外部图片、下载字体或模型调用。使用 XeLaTeX、CTeX、Source Han Serif SC、Noto Sans SC 和已安装的拉丁字体。禁止 shell escape，重复编译使目录、交叉引用和引用编号稳定。

Listing 2: 从项目根目录编译技术报告的命令。

```
mkdir -p artifacts/technical_report_20260930
xelatex -no-shell-escape -interaction=nonstopmode \
  -halt-on-error -output-directory=artifacts/technical_report_20260930 \
  docs/reports/cv_agent_technical_report_2026-09-30.tex
# Run xelatex again until cross-references are stable.
```

报告构建记录单独保存在 `artifacts/technical_report_20260930/`；可交付 PDF 与 LaTeX 源码位于 `docs/reports/`。构建记录的源码哈希、页数、结构检查和渲染检查仅证明这份文档可追溯，不是检测器或模型实验的 gate receipt。

19.2 引用规则与事实更新

文中实现定位以仓库根目录为基准。引用的源码标识用于说明职责，参考资料的日期和版本用于约束事实时态。`CURRENT_STATUS` 的历史段落、完整系统目标规格和早期“当前”措辞都需结合其写作快照理解。

最终汇总 JSON 已将 K2 更新为完成、G-A 更新为正式 NO，并把统计来源更正为架构方查询、由用户转述。修正前的字段保存在明确标为 historical snapshot 的对象内。后续事实更新应修改当前状态并保留历史，不通过复写原始实验来让报告结论变好。

A 核心模块阅读索引

表中路径以 `src/cv_agent/` 为基准；同一行的短文件名或子目录沿用首项显示的所属包。

表 17: 源码定位与理解顺序。所有路径均以 `src/cv_agent/` 为前缀。

位置	应阅读的逻辑
`domain/types.py`, `evidence.py`, `review.py`, `chat.py`	候选、subject、观察、任务与票，以及 provider-neutral 消息和 usage。
`domain/validation_protocol.py`	准备状态、缺字段 destination、dataset/model 模式及继续动作。
`code_adapters/python.py`, `java.py`, `javascript.py`, `go.py`	多语言切片、定义、调用与元数据的生成。
`code_adapters/source_files.py`, `fallback.py`, `repository.py`	安全读取、fallback 层级及仓库文档组装。
`agents/discovery.py`, `scanner.py`	标签无关的 Python 源码清单与有限候选规则。
`retrieval/index.py`, `context.py`, `dependencies.py`, `tokens.py`	图绑定、文本/图/hybrid 排序、局部窗口、预算和序列化拟合。
`retrieval/bm25.py`	独立 BM25 元数据诊断。
`agents/workflow.py`	LangGraph 状态、依赖调度、累积票与最终结果。
`agents/planning.py`, `plan_policy.py`	计划提示、schema、必要任务与政策组合。
`agents/react.py`	模型/工具循环、纠正、final-only 阶段及用量累计。
`agents/evidence_policy.py`	性质与范围准入、相关反证、冲突、投递及必需验证完成。
`agents/routing.py`, `applicability.py`	可选 Jev 分流及独立专家适用性政策。
`agents/voting.py`, `validator_accounting.py`	单票/quorum、早停与原始观察共享计数。
`tools/registry.py`, `repository.py`, `identity.py`	工具 schema 与作用域、源码查询、重复记忆及 subject 构造。
`tools/analysis/commands.py`, `python_flow.py`, `python_probe.py`	有界命令、数据流和 AST 输入探针。
`tools/validation/permissions.py`, `authorization.py`, `commands.py`	对应性质的观察封装与语义边界。
`tools/validation/fixtures.py`, `comparison.py`	注册夹具、loopback 案例与源码差分。

位置	应阅读的逻辑
`tools/validation/bounded_witness.py`, `witness_manifest.py`, `witness_scenario.py`, `witness_response.py`	见证服务、系统清单、分类场景和 compact 投递。
`runtime/witness/kernel.py`, `contract.py`, `scenario_runtime.py`	源码绑定 worker、正向 proof contract 与场景执行。
`runtime/witness/obligations/values.py`, `branches.py`, `preexec.py`	真实值、分支和 preexec 义务。
`runtime/witness/accounting.py`, `tracer.py`, `isolation_policy.py`	执行资源、读取追踪与身份绑定准入。
`runtime/model.py`, `provider.py`, `admission.py`, `jev.py`	传输、provider 组装、完整 pytest 门禁和 choice 协议。
`runtime/budget.py`, `journal.py`, `snapshots.py`, `provenance.py`	预算、耐久事件、源码快照及 Git 身份。
`harness/models.py`, `defaults.py`, `validation.py`	不可变实验声明、E/V 默认系统和约束核对。
`evaluation/execution.py`, `lifecycle.py`, `results.py`, `metrics.py`	候选执行、实验组织、输出、三值指标和配对比较。
`evaluation/datasets/`, `protocols/`, `discovery.py`	数据角色、输入/标签分离、专项验收与发现计分。
`evaluation/preparation/prepare_witness_environment.py`, `witness_import_worker.py`, `witness_metadata.py`	锁定环境、metadata-only 目标安装、受限导入与上下文产物。
`evaluation/runners/`, `diagnostics/`	显式实验入口、审计、预检和已完成运行复核；不能仅凭名字认定调用离线。
`baselines/`, `cli.py`	确定性历史对照与命令派发。

B 工具目录与输出解释

表 18: 当前注册工具族。工具是否可用及可支持的证明状态由本次运行的能力声明决定。

工具	职责和主要限制
`search_symbols`	在准入文档中搜索符号，不扩展检索路径。
`read_span`	读取已准入切片或范围，完整响应按序列化预算计数。

工具	职责和主要限制
`get_callers`, `get_callees`	提供已建立图边与有限邻居，图事实不直接证明动态可达。
`find_references`	在准入源码中查找引用，保留缺失和绑定限制。
`run_static_check`	发现有限模式与操作类型，保持静态观察范围。
`find_sources`, `find_sinks`, `find_sanitizers`	定位来源、消费和处理候选；存在名称不是完整证明。
`trace_dataflow`	有界 may-flow、参数绑定和缺边记录；保持 UNRESOLVED。
`inspect_command_construction`	命令来源、转换、路径、消费上下文和执行效果检查。
`probe_python_eval`	有界 AST 输入控制探针，匹配动态求值性质。
`validate_permission_mode`	特定权限 mode 性质的静态验证，不能证明目录竞态。
`get_routes`, `get_guards`	路由与守卫事实；没有匹配不表示绕过成立。
`inspect_principal`, `inspect_resource_scope`	主体及对象/租户范围的有界提取。
`compare_route_and_service_guard`	已准入路由及服务调用链的守卫对照。
`run_fixture_test`	运行注册项目夹具，必须匹配 subject、性质和充分 proof scope。
`run_loopback_http_case`	项目自有 loopback 的授权行为对照；不替代其他性质证明。
`compare_vulnerable_and_fixed`	显式配对的源码与行为上下文，diff 自身不构成漏洞确认。
`run_bounded_execution_witness`	系统清单、分类场景与受限真实入口的正向确认；字面量和失败均未决。

实现定位：`src/cv_agent/tools/repository.py;tools/validation/registry.py;tools/validation/models.py`

C 单候选审查的完整记录链

以下是当前机制的概念性逐步追踪，不包含目标专属输入或可执行漏洞复现数据。

1. 固定源码快照，从配置或扫描器得到显式候选、性质、位置和范围。
2. 构建 RepositoryIndex，生成 subject 并执行本次系统声明的检索。
3. 序列化候选与检索文档，在预算内生成最终 admitted paths 和审计记录。
4. 如系统开启 planner，组合必要任务、有效模型计划或可选 routing 决策，校验依赖与允许验证器。
5. 对就绪任务生成独立 scope，继承同专家已用预算及合法可见依赖观察。

6. 模型提出工具动作；注册表检查预算、allowlist、schema、案例绑定和相同调用记忆。
7. 工具产生完整观察，运行时给出 citation 与投递状态，记录实际生产者和物理执行信息。
8. 对准备响应继续补数据；对于实际未决观察保留 gap；对于候选充分证明保存其性质范围。
9. 模型提出最终 JSON；证据准入核对所有相关事实、引用和必需验证器完成。
10. 保存任务中间执行。专家全部任务处理完后，只保留一张累积最终票；未完成验证阻塞依赖。
11. E5 如可用则尝试固定前缀早停；否则按全量规则裁决，受阻必需依赖导致弃权。
12. 结果汇总包含 task executions、blocked tasks、votes、原始观察计数、上下文成本和真实模型 usage。
13. evaluator 在独立侧读取参考标签, 计算本次协议的计分、运行完整性和 claim readiness。

D 术语对照

术语	本报告中的定义
Candidate	明确位置、性质和范围的待检对象；不是已经确认的漏洞。
Subject	验证证据的候选与源码绑定；前提参与身份。
Observation	工具操作所得事实或失败记录，具有执行与投递状态。
Proof scope	验证器实际支持的性质、范围、方法和状态。
Preparation	执行见证前的缺字段或协议纠正状态，不算验证完成。
Validator completed	规定的验证器已经完成其工具协议；其语义结果可以仍然未决。
Ballot	每位专家最终的一张累积票；任务中间判断不是新增票。
Producer observation	某次任务执行中的原始工具观察；引用副本不是新生产者。
Witness	受声明场景限制的有界执行观察与验证；不自动包含远程权限。
Operational readiness	本次运行及产物能被完整审查。
Claim readiness	满足独立数据角色、实验完整性、证据和研究声明前提。
Historical snapshot	保留当时状态，用于追溯；当前状态从主字段及明确的后续判定读取。

参考文献

[1] cv-agent 项目. 测试与语义契约 C1–C6、T01–T16. `docs/TEST_CONTRACT.md`.

[2] cv-agent 项目. 当前状态，2026-09-30. `docs/CURRENT_STATUS.md`，以开头收尾状态为准。

[3] cv-agent 项目. 架构与阅读路线. `docs/ARCHITECTURE.md`，结合当前源码与 K2 迁移理解。

[4] cv-agent 项目. 实验指南. `docs/EXPERIMENTS.md`，历史入口不构成新运行授权。

[5] cv-agent 项目. 完整系统目标规格. `docs/reference/FULL_SYSTEM_SPEC.md`，属于设计目标而非全部实现验收声明。

[6] cv-agent 项目. 项目流程与诊断. `docs/reference/PROJECT_FLOW_AND_DIAGNOSIS.md`，实验状态按文档日期解读。

[7] cv-agent 项目. 模型提出场景接口. `docs/reference/MODEL_PROPOSED_WITNESS_SCENARIOS.md`，结果更新见 E-iter 与 M0。

[8] cv-agent 项目. 2c 实际见证验收，2026-09-28. `.hermes/plans/2026-09-28-witness-stage2c-results.md`.

[9] cv-agent 项目. K1 实测范围与投递验收，2026-09-29. `.hermes/plans/2026-09-29-k1-results.md`.

[10] cv-agent 项目. K2 迁移验收，2026-09-30. `.hermes/plans/2026-09-30-K2-results.md`；`.hermes/plans/2026-09-30-K2-results.json`.

[11] cv-agent 项目. K3 环境重建，2026-09-30. `.hermes/plans/2026-09-30-K3-results.md`.

[12] cv-agent 项目. K4 离线共享观察验收，2026-09-30. `.hermes/plans/2026-09-30-K4-results.md`.

[13] cv-agent 项目. M0 授权、阶段、失败分类及收尾要求，2026-09-29. `.hermes/plans/2026-09-29-remaining-work-plan.md`.

[14] cv-agent 项目. 剩余架构 K1–K8，2026-09-29. `.hermes/plans/2026-09-29-remaining-architecture.md`.

[15] cv-agent 项目. E-iter 实际探索结果，2026-09-30. `.hermes/plans/2026-09-30-E-iter-results.md`；`.hermes/plans/2026-09-30-E-iter-results.json`.

[16] cv-agent 项目. M0 阶段 4 与收尾更新，2026-09-30. `.hermes/plans/2026-09-30-remaining-work-final-report.md`；已同步的 `.hermes/plans/2026-09-30-remaining-work-final-summary.json`.

[17] cv-agent 项目. 正式 G-A 判定，2026-09-30. `.hermes/plans/2026-09-30-G-A-decision.md`；`.hermes/plans/2026-09-30-G-A-decision.json`.

[18] cv-agent 项目. 有界见证定位报告，2026-09-30. `.hermes/plans/2026-09-30-positioning-report.md`.

[19] cv-agent 项目. 架构方 held-out 信息访问披露，2026-09-30 补记. `.hermes/plans/2026-09-30-architect-exposure-disclosure.md`.